

별표 2 모바일 서비스 서버(웹·앱) 대상 보안취약점 점검기준

번호	점검 항목	설명	비고
1	운영체제 명령실행	웹 서버에 존재하는 명령어 실행 가능 함수 인자를 조작하여 특정 명령어 실행이 가능한 취약점	
2	SQL인젝션	입력 폼에 악의적인 쿼리문을 삽입하여 DB 정보, 타 사용자 권한 획득이 가능한 취약점	
3	XPath인젝션	XPath 쿼리문 구조를 임의로 변경하여 DB 정보 열람, 타 사용자 권한 획득이 가능한 취약점	
4	정보누출	개발자의 부주의, 디폴트로 설정된 에러 페이지 등 웹 어플리케이션에서 민감한 정보가 노출되는 취약점	
5	악성콘텐츠	정상적인 콘텐츠 대신에 악성 콘텐츠를 주입하여 사용자에게 악의적인 영향을 미치는 취약점	
6	크로스사이트 스크립트	웹 사이트를 통해 다른 최종 사용자의 클라이언트에서 임의의 스크립트가 실행되는 취약점	
7	약한 문자열 강도	비밀번호 조합규칙(영문, 숫자, 특수문자 등)이 충분하지 않아 추측 가능한 취약점	
8	불충분한 인증 및 인가	웹 어플리케이션에서 사용자 인증 및 접근제한 미흡으로 불법 접근 및 조작이 가능한 취약점	
9	취약한 패스워드 복구	취약한 패스워드 복구로직을 통해 다른 사용자의 패스워드를 획득, 변경할 수 있는 취약점	
10	불충분한 세션관리	단순 숫자 증가 방법 등의 취약한 특정 세션의 ID를 예측하여 세션을 가로채거나 중복 접속을 허용하는 경우 타 사용자의 세션을 획득하여 권한 획득 할 수 있는 취약점	
11	크로스사이트 리퀘스트 변조(CSRF)	공격자 스크립트 구문을 이용하여 정상적인 사용자로 하여금 조작된 요청을 전송하도록 하여 회원 등급 변경 등의 문제가 발생할 수 있는 취약점	
12	자동화공격	정해진 프로세스에 자동화된 공격을 수행함으로써 수많은 프로세스가 진행되는 취약점	
13	파일업로드	파일 업로드 기능을 이용하여 시스템 명령어를 실행할 수 있는 파일을 업로드 하는 취약점	
14	경로추적 및 파일다운로드	다운로드 함수 인자를 조작하여 서버에 존재하는 파일 다운로드 가능한 취약점	
15	데이터 평문전송	서버와 클라이언트 간 통신 시 암호화 하여 전송을 하지 않아 중요 정보 등이 노출되는 취약점	
16	쿠키 변조	보호되지 않는 쿠키를 사용하여 값 변조를 통한 사용자 위장 및 권한 상승 등이 가능한 취약점	
17	URL/파라미터 변조	URL, 파라미터의 값을 검증하지 않아 특정 사용자의 권한 획득이 가능한 취약점	
18	디렉토리 인덱싱	본 페이지의 파일이 존재하지 않을 때 자동적으로 디렉토리 리스트를 출력하는 취약점	
19	관리자페이지 노출	단순한 관리자 페이지 이름, 설정, 설계상 오류 등 관리자 메뉴에 직접 접근할 수 있는 취약점	
20	위치공개	임시파일, 백업파일등에 접근이 가능하여 핵심정보가 노출될 수 있는 취약점	
21	웹 서비스 메소드 설정 공격	PUT, DELETE 등의 메소드를 악용하여 악성 파일(웹쉘) 업로드가 가능한 취약점	